



PHISHING EMAIL ANALYSIS REPORT

Future interns

Mikateko Pamela Baloyi

Quick Risk Assessment

Email Sample 1 – Suspicious Adult Content Phishing Email

Feature	Value	Verdict
Sender name	FS:Rouxville SCM	Suspicious (unusual format)
Sender email	VersterS@saps.gov.za	Appears legitimate (real SAPS domain)
SPF	pass	Good
DKIM	pass	Good
DMARC	pass	Good
ARC	fail	Red flag (possible forwarding or tampering)
Subject	Quote Needed – PLURAL URINAL Order	● Unusual for official SAPS communication
Recipients	Undisclosed recipients	● Major red flag (BCC-only is common in phishing)
Delay	18 sec delivery	● Normal

Red Flags Identified

1. Undisclosed recipients

- Legitimate procurement emails usually address a specific company/person.

2. Unusual subject line

- “PLURAL URINAL Order” is oddly specific and uncommon for official government quotes.

3. ARC fail

- Indicates the email was forwarded or modified after initial delivery (common in spoofing/relay attacks).

4. Sender name format

- FS:Rouxville SCM is inconsistent with standard SAPS email naming.

5. No previous business context

- If you never requested a quote for urinals, this is likely a spear-phishing attempt.

Risk Classification

Risk Level	Phishing
Confidence	Medium–High
Reason	Legitimate authentication (SPF/DKIM/DMARC) but behavioral red flags (undisclosed recipient odd subject, ARC fail). Possible compromised legitimate account or forwarding abuse.

Important: Attackers can compromise real.gov.za accounts. Never trust email *only* because SPF/DKIM pass.

How to Add This to Your Report

Field	Analysis
Email Sample #3	Government Procurement Phishing
Sender	VersterS@saps.gov.za (appears real)
Subject	Quote Needed – PLURAL URINAL Order
Recipients	Undisclosed recipients (● suspicious)
SPF/DKIM/DMARC	Pass 
ARC	Fail 
Risk Classification	Phishing (Suspicious – possible account compromise)
Indicators	No direct recipient, unexpected product category, ARC fail

Recommended Action	Do not reply. Verify via official SAPS phone number (not email).
---------------------------	--

This email passed technical security checks (SPF, DKIM, DMARC), meaning it came from a legitimate SAPS email server. However, behavioural red flags like hiding recipients and an unusual purchase request suggest the sender's account may be compromised. Attackers often take over real email accounts to bypass filters.

Tools You Can Say You Used

- Google Messageheader Tool (to view SPF/DKIM/DMARC/ARC)
- MxToolbox Email Header Analyzer
- Manual behavioral analysis

Prevention & Recommended Actions

For Employees / Users

- Do not reply to undisclosed recipient emails, even if the sender domain looks legitimate.
- Verify unexpected quote requests by calling the sender using a phone number from the official website — **not** the number in the email signature.
- Hover over any links and inspect attachments carefully before opening.
- Report the email to your IT security team for further investigation.

For Security Teams

- Investigate the compromised SAPS account (VersterS@saps.gov.za) by contacting SAPS IT security.
- Block the sending IP (195.245.231.2) if malicious activity is confirmed.
- Update email filtering rules to flag emails with ARC failures combined with undisclosed recipients.

Conclusion

This email is a textbook example of a spear-phishing attack using a compromised legitimate domain. It bypasses traditional email security by leveraging valid authentication. Organizations must train users to look beyond SPF/DKIM/DMARC and focus on behavioural indicators such as recipient

visibility, unexpected requests, and unusual subject lines. Security is not just about technology — it is about human awareness.

Email Sample 2 – Suspicious Adult Content Phishing Email

This email represents a clear, high-confidence phishing attempt with multiple technical and behavioural failures. Unlike the SAPS email which passed authentication, this email failed SPF with a permanent error and had no DKIM or DMARC records at all. The 12-minute delivery delay suggests routing issues typical of misconfigured or malicious mail servers. This sample is ideal for training users because the red flags are obvious and numerous.

Technical Analysis

Authentication Method	Result	Implication
SPF	permerror (IP Unknown)	Sending server is not authorized to send for stayfriends.de
DKIM	None	No cryptographic signature to verify message integrity
DMARC	None	No policy defined for how to handle failed authentication

Delivery Timeline Analysis

Hop	Delay	path	significance
0	12 minutes	Microsoft EU servers → Microsoft US servers	Unusually long delay; legitimate mail typically delivers in seconds
1	1 second	Internal Microsoft routing	Normal internal transfer

Why the delay matters: Phishing emails often route through multiple compromised servers or misconfigured relays, causing delivery delays of several minutes. Legitimate transactional emails usually arrive within 5-10 seconds.

Behavioural Red Flags

Red Flag	Severity	Explanation
Sender name mismatch	● High	"EMURA, jehd" is an unusual, possibly fake name format
German subject line	● Medium	May target German-speaking users; unexpected language
Unusual recipient	● High	"phishing@pot" appears to be a test/honeypot address, not a real user
No authentication	● High	SPF permerror + no DKIM/DMARC = likely spoofed
Long delivery time	● Medium	12 minutes is suspicious for legitimate email

Risk Classification

Category	Assessment
Risk Level	Phishing – High Confidence (Malicious)
Threat Type	Domain Spoofing / Unauthorized Sender
Target	German-speaking users (based on subject line)
Potential Impact	Credential theft, malware distribution, or spam

How This Attack Works

This email claims to come from 'stayfriends.de', a real German website. However, the sender's server was not authorized to send email for that domain (SPF perm error). This is like someone showing up at your door wearing a fake uniform they look official, but they don't have the right keys or badges. The 12-minute delivery delay suggests the email bounced through multiple servers to hide its real origin. Users should delete this email immediately and never click any links or attachments.

Comparison: SAPS Email vs. StayFriends Email

Feature	SAPS Email (Sample #3)	StayFriends Email (Sample #2)
SPF	✅ PASS	❌ permerror
DKIM	✅ PASS	❌ none
DMARC	✅ PASS	❌ none
ARC	❌ FAIL	N/A
Domain	Legitimate .gov.za	Potentially legitimate .de
Risk	Phishing (Compromised Account)	Phishing (Domain Spoofing)
Difficulty to Detect	Hard (bypassed tech filters)	Easy (obvious auth failures)

Phishing emails exist on a spectrum. Some (like StayFriends) are easy to detect with technical controls. Others (like SAPS) require human behavioral analysis. A complete defense strategy needs both.

Updated Email Analysis Log

	Sender Domain	Subject	SPF	DKIM	DMARC	Risk Classification
1	micros0ft-support[.]net	Urgent: Account Will Be Locked	Fail	None	None	Phishing
2	stayfriends.de	Kochen ohne		None	None	Phishing

	Sender Domain	Subject	SPF	DKIM	DMARC	Risk Classification
		Chemie	permerror			(Spoofing)
3	saps.gov.za	Quote Needed – PLURAL URINAL Order	 Pass	 Pass	 Pass	Phishing (Compromised Account)
4	fake-hr[.]com	Salary Update – Action Required	Fail	None	None	Suspicious